

UNDERSTANDING THE CIA TRIAD

GUARDING THE DIGITAL WORLD: UNDERSTANDING THE CIA TRIAD WITH
REAL-WORLD EXAMPLES
SELO DAVID SETHIBO

Introduction

Cybersecurity is the practice of protecting information, computer systems, networks, applications, and other digital resources from unauthorized access, misuse, modification, disruption, or destruction.

Organizations depend heavily on information systems to perform their daily activities. Banks use computer systems to process transactions, businesses store customer information electronically, and governments use digital systems to provide important services. Because of this dependence, organizations need to ensure that their information remains private, accurate, and accessible to authorized users.

One of the fundamental concepts used in information security is the **CIA Triad**. CIA stands for:

Confidentiality

Integrity

Availability

The CIA Triad provides a foundation for understanding what needs to be protected in an information system. A security incident may affect one or more of these three principles.

For example, if an attacker steals customer information, confidentiality has been affected. If an attacker changes information without authorization, integrity has been affected. If an attack causes a system to become unavailable, availability has been affected.

Therefore, understanding the CIA Triad is important for cybersecurity professionals because it helps them identify security requirements, understand the effects of incidents, and select appropriate security controls.

1. Confidentiality

What is Confidentiality?

Confidentiality means ensuring that information is only accessible to authorized individuals or systems.

The main purpose of confidentiality is to prevent unauthorized people from viewing, accessing, copying, or disclosing sensitive information.

Organizations may store different types of sensitive information, including:

- ❖ Personal information
- ❖ Passwords and authentication credentials
- ❖ Financial information
- ❖ Customer records
- ❖ Business documents
- ❖ Employee information
- ❖ Security information
- ❖ Confidential communications

If unauthorized individuals gain access to this information, the organization and the affected individuals may face serious consequences.

For example, imagine an online banking system. A customer's account information should only be accessible to the customer and authorized banking employees. An unauthorized person should not be able to view the customer's account balance, personal information, or transaction history.

This is the purpose of confidentiality.

How can confidentiality be protected?

Organizations can use several security controls, including:

- ❖ **Encryption:** converts information into a protected format that cannot easily be understood without the appropriate key. For example, sensitive information transmitted across a network can be encrypted so that an attacker who intercepts the communication cannot easily read it.
- ❖ **Multi-Factor Authentication (MFA):** requires users to provide additional verification beyond a password. For example, a user may need a password together with a code sent to a mobile device. This provides an additional layer of protection if a password is stolen.
- ❖ **Access Control:** determines who is allowed to access specific information or systems. For example, an employee working in the finance department may have access to financial records, while another employee may not have permission to view them.
- ❖ **Strong Passwords:** strong and unique passwords reduce the risk of unauthorized account access. Organizations should also encourage users not to reuse passwords across different systems.
- ❖ **Least Privilege:** the principle of least privilege means giving users only the access they need to perform their responsibilities. This limits the amount of information that can be accessed if an account is compromised.

Real-World Example: Equifax Data Breach

The **2017 Equifax data breach** is an example of a confidentiality failure. Attackers gained unauthorized access to sensitive personal information belonging to millions of individuals. Information such as names, addresses, dates of birth, and Social Security numbers was exposed. This demonstrates a failure of confidentiality because sensitive information was accessed by unauthorized parties.

Key lesson

Organizations should protect sensitive information through measures such as:

- ❖ Timely security patching
- ❖ Strong authentication
- ❖ Access management
- ❖ Encryption
- ❖ Security monitoring
- ❖ Proper vulnerability management

Confidentiality is therefore not simply about keeping information secret. It is about ensuring that only authorized users and systems can access the information.

2. Integrity

What is Integrity?

Integrity means ensuring that information remains accurate, complete, trustworthy, and protected from unauthorized modification. Information can be confidential and available but still be dangerous if it has been changed without authorization.

For example, consider a banking system. If an attacker changes a customer's account balance from M10,000 to M1,000 without authorization, confidentiality may not necessarily have been violated. However, the integrity of the information has been compromised because the information is no longer accurate. Integrity is therefore concerned with protecting information from unauthorized changes.

Integrity applies to more than just databases. It can also apply to:

- ❖ Software
- ❖ System configurations
- ❖ Financial records
- ❖ Database records
- ❖ Network configurations
- ❖ Documents
- ❖ Logs
- ❖ Applications
- ❖ Security policies

How can integrity be protected?

Examples of controls include:

- ❖ **Cryptographic hashing:** a cryptographic hash can be used to detect whether information has changed. A file can be hashed before transmission and then hashed again later. If the hash values are different, this can indicate that the file has been modified.
- ❖ **Digital signatures:** digital signatures can help verify the authenticity and integrity of digital information. They can help determine whether information came from the expected source and whether it was changed after being signed.
- ❖ **Access controls:** access controls can restrict who is allowed to modify information. For example, ordinary users may be allowed to view a database record but only authorized administrators may be allowed to change it.
- ❖ **Audit logs:** audit logs record activities performed on systems. For example, logs can record which account changed a file, when the change occurred, and what activity took place. This can help organizations investigate unauthorized modifications.

Real-World Example: SolarWinds Attack

The 2020 SolarWinds supply-chain attack provides an important example of an integrity compromise. In a software supply-chain attack, attackers can target a trusted software provider rather than directly attacking every organization that eventually becomes affected.

The SolarWinds case involved the compromise of the software development and update process. Malicious code was inserted into legitimate software updates, meaning that customers who installed affected updates unknowingly received compromised software.

The SolarWinds research article describes this as a software supply-chain attack in which attackers compromised the integrity of software and inserted malicious code into the legitimate software development and update process. The important connection to the CIA Triad is integrity. The software was expected to be trustworthy. However, it had been modified before it reached customers.

This demonstrates that protecting integrity is not limited to protecting files stored inside an organization. Organizations also need to consider the integrity of software and services received from trusted third-party suppliers. The Solar Winds case also demonstrates why organizations should not automatically assume that something is safe simply because it comes from a trusted supplier.

Key lesson

Organizations should implement mechanisms that can help verify that:

- ❖ Software has not been modified without authorization.
- ❖ Files have not been tampered with.
- ❖ System configurations remain trustworthy.
- ❖ Updates come from legitimate sources.
- ❖ Important changes are recorded and monitored.
- ❖ Third-party software and suppliers are properly assessed.

The SolarWinds incident shows that trust must be supported by verification.

3. Availability

What is Availability?

Availability means ensuring that authorized users can access systems, applications, services, and information when they need them. A system can have strong confidentiality and integrity, but if authorized users cannot access it, the system cannot perform its intended function.

For example, consider an online banking system. The system may protect customer information from unauthorized access and ensure that account balances are accurate. However, if customers cannot access their accounts or perform transactions because the system is unavailable, the organization is still experiencing a security and operational problem.

Availability is particularly important for organizations that provide critical services.

What can affect availability?

Availability can be affected by:

- ❖ Distributed Denial-of-Service (DDoS) attacks
- ❖ Ransomware
- ❖ Hardware failures
- ❖ Power failures
- ❖ Network failures
- ❖ Human configuration errors
- ❖ Other cyber incidents

This means that availability is not only a cybersecurity issue. It can also be affected by technical failures, environmental problems, and human mistakes.

How can availability be protected?

Organizations can use:

- ❖ **Backups:** provide copies of important information that can be used when the original information becomes unavailable. Organizations should regularly test backups rather than assuming that they will work when needed.
- ❖ **Redundant systems:** allows another system or component to continue providing a service when the primary system fails. For example, an organization may have backup servers or network connections.
- ❖ **Disaster recovery plans:** a disaster recovery plan provides procedures for restoring systems and services following a serious incident. It helps organizations understand what should happen after a major system failure.
- ❖ **DDoS protection:** protection can help organizations deal with large amounts of malicious traffic intended to make online services unavailable
- ❖ **System monitoring:** continuous monitoring can help organizations identify system failures, unusual activity, and security incidents more quickly.

Real-World Example: Central Bank of Lesotho

A useful local example of availability is the December 2023 cybersecurity incident involving the Central Bank of Lesotho (CBL). According to a December 2023 MyBroadband report, the Central Bank of Lesotho confirmed that it had experienced a cybersecurity incident on 11 December 2023. The bank stated that it was investigating the matter and working to restore its systems. It also said that some systems had been suspended to prevent further infiltration, which resulted in some payments being delayed.

The incident affected the National Payments System. In a follow-up statement, the Central Bank acknowledged that the outage made it impossible for local banks to honour inter-bank transactions normally. The bank, together with other relevant parties, worked on technical solutions and business continuity measures to facilitate payments while the system was being restored.

This is a strong example of why availability is important. The issue was not simply whether information was confidential or accurate. The problem was that an important financial system was not available for normal operations. It affected the ability of banks to perform normal inter-bank transactions and therefore demonstrated the operational impact that can occur when a critical system becomes unavailable.

Importantly, the available report does not specify the exact technical nature of the attack. Therefore, it would be inappropriate to describe the incident as ransomware, DDoS, or another specific type of attack without additional evidence.

Key lesson

Critical organizations such as financial institutions need strong:

- ❖ Backup systems
- ❖ Disaster recovery plans
- ❖ System monitoring
- ❖ Incident response procedures

- ❖ Business continuity processes
- ❖ Recovery capabilities

The Central Bank of Lesotho incident demonstrates that cybersecurity is also about maintaining essential services when a security incident occurs.

The CIA Triad in Practice

The three principles are connected.

For example, consider an online banking system:

CIA Principle	Example
Confidentiality	Only the account owner and authorized bank employees can access account information.
Integrity	Account balances and transactions must not be changed without authorization.
Availability	Customers should be able to access their accounts and perform transactions when the service is available.

For example, an attacker could steal a customer's login credentials. This could result in a **confidentiality** problem if the attacker accesses private information. If the attacker changes the customer's account information or transactions, this could also become an **integrity** problem. If the attacker causes the banking service to become unavailable, this could become an **availability** problem. Therefore, the three principles should be considered together.

Why the CIA Triad Matters in cybersecurity

The CIA Triad gives cybersecurity professionals a simple framework for understanding what needs to be protected. It helps organizations ask three important questions:

- ❖ **Confidentiality:** who should be allowed to access this information?
- ❖ **Integrity:** how can we make sure this information remains accurate and has not been changed without authorization?
- ❖ **Availability:** how can we ensure that authorized users can access the system when they need it?

These questions can be applied to almost every information system.

For example:

- ❖ A hospital must protect patient information from unauthorized access.
- ❖ A bank must ensure that financial transactions are accurate.
- ❖ A university must ensure that students and staff can access important systems.
- ❖ A government institution must maintain access to critical digital services.
- ❖ A business must protect customer information while keeping its systems operational.

The CIA Triad therefore provides a foundation for identifying security requirements and evaluating the possible impact of security incidents.

- ❖ A data leak can affect **confidentiality**.
- ❖ Unauthorized modification can affect **integrity**.
- ❖ A system outage can affect **availability**.

Relationship Between the Three Principles

The CIA Triad should not be viewed as three completely separate areas. They work together to support trustworthy information systems. For example, imagine an organization has a database containing customer information.

First, **confidentiality** ensures that unauthorized people cannot access the database.

Second, **integrity** ensures that authorized information remains accurate and is not changed improperly.

Third, **availability** ensures that authorized employees and systems can access the database when it is required.

If one principle fails, the organization may experience serious consequences.

1. A system that protects confidentiality but is unavailable cannot effectively provide its service.
2. A system that is available but contains incorrect information cannot be trusted.
3. A system that is accurate and available but exposes sensitive information to unauthorized users still has a security problem.

This is why an effective cybersecurity strategy needs to consider all three principles.

Practical Security Controls Based on the CIA Triad

Principle	Main Security Goal	Example Controls
Confidentiality	Prevent unauthorized access or disclosure	Encryption, MFA, access control, strong passwords
Integrity	Prevent unauthorized modification	Hashing, digital signatures, access control, audit logs
Availability	Keep systems and information accessible	Backups, redundancy, disaster recovery, monitoring

This table demonstrates how the CIA Triad can be connected directly to practical cybersecurity controls. Security professionals can use this approach when assessing an organization's systems

Lessons from the Real-World Examples

The three examples demonstrate different areas of the CIA Triad.

❖ **Equifax - Confidentiality**

The Equifax data breach demonstrates the consequences of unauthorized access to sensitive personal information.

Lesson: Sensitive information must be protected against unauthorized access and disclosure.

❖ **SolarWinds - Integrity**

The SolarWinds supply-chain attack demonstrates the importance of protecting software and update processes from unauthorized modification.

Lesson: Organizations need ways to verify the integrity and authenticity of software and information.

❖ **Central Bank of Lesotho - Availability**

The 2023 Central Bank of Lesotho incident demonstrates how a cybersecurity incident can affect the availability of critical financial services.

Lesson: Critical organizations need effective recovery, monitoring, incident response, and business continuity capabilities.

Together, these examples show that cybersecurity is not only about preventing hackers from accessing information. It is also about ensuring that information remains trustworthy and that important systems continue to operate.

Conclusion

The CIA Triad (Confidentiality, Integrity, and Availability) is a fundamental concept in cybersecurity.

Confidentiality protects information from unauthorized access and disclosure.

Integrity ensures that information remains accurate, complete, and trustworthy and is not modified without authorization.

Availability ensures that authorized users can access systems, applications, and information when they need them.

The Equifax data breach demonstrates the importance of protecting confidentiality. The SolarWinds supply-chain attack demonstrates the importance of protecting integrity throughout software development and distribution. The Central Bank of Lesotho incident demonstrates the importance of maintaining availability for critical financial services.

These examples show that cybersecurity requires a balanced approach. Organizations must protect information from unauthorized access, protect it from unauthorized modification, and ensure that critical systems remain available.

For cybersecurity professionals, understanding the CIA Triad provides a strong foundation for identifying security risks, selecting appropriate security controls, investigating incidents, and protecting information systems.

Ultimately, a secure information system should provide information that is private when it needs to be private, trustworthy when it needs to be trusted, and available when it needs to be available.